

ABC Healthcare Services

PASSWORD POLICY

Information Security Governance Program

Field	Details
Document ID	PWD-001
Version	1.0
Classification	Internal
Policy Owner	Information Security Manager
Approved By	Executive Management
Effective Date	June 1, 2026
Review Date	June 1, 2027

. Document Revision History

Version	Date	Description	Author
1.0	June 1, 2026	Initial Release	Information Security Manager

1. Purpose

The purpose of this Password Policy is to establish minimum password and authentication requirements designed to protect ABC Healthcare Services' information systems, applications, networks, and information assets from unauthorized access.

Strong password management practices significantly reduce the risk of credential theft, account compromise, unauthorized disclosure of information, and cybersecurity incidents. This policy supports regulatory compliance, organizational security objectives, and industry best practices.

Risk Statement

Failure to comply with this policy may result in unauthorized access to organizational systems, data breaches, service disruptions, financial losses, regulatory penalties, and reputational damage.

2. Scope

This policy applies to all employees, contractors, consultants, vendors, third-party service providers, temporary personnel, and authorized users who access ABC Healthcare Services information systems. The policy applies to all user accounts, administrator accounts, service accounts, applications, cloud environments, mobile devices, network infrastructure, and business systems.

3. Policy Objectives

- Protect organizational information assets.
- Reduce the risk of unauthorized access.
- Enforce strong authentication practices.
- Support regulatory and compliance requirements.
- Improve cybersecurity resilience.
- Promote security awareness among users.
- Support information governance and access management initiatives.

4. Password Requirements

4.1 Password Complexity Standards

All passwords must meet the following minimum requirements:

Requirement	Standard
Minimum Length	14 Characters
Uppercase Letters	Required
Lowercase Letters	Required
Numbers	Required
Special Characters	Required
Dictionary Words	Not Allowed
Personal Information	Not Allowed
Password Reuse	Prohibited

4.2 Password Creation Guidelines

Passwords should:

- Be unique and difficult to guess.
- Avoid names, birthdays, or personal information.
- Avoid predictable patterns.
- Be different from previously used passwords.
- Not be shared with any individual.

Examples of Weak Passwords

- Password123
- Welcome2026
- Company123
- Admin2026

Examples of Strong Passwords

- M@Secure2026!Cloud#
- S3curity\$Shield#2026
- C0mpl1ance!Risk@2026

5. Password Management Requirements

Users are responsible for maintaining the confidentiality of their passwords.

Users must:

- Keep passwords confidential.
- Never share passwords.
- Never write passwords on visible surfaces.
- Use approved password managers if available.
- Report any suspected password compromise immediately.

Passwords must not be transmitted through unsecured communication channels.

6. Multi-Factor Authentication (MFA)

Multi-Factor Authentication (MFA) is mandatory for all critical systems and applications.

MFA must be enabled for:

- VPN access
- Microsoft 365 accounts
- Cloud services
- Administrative accounts
- Financial systems
- Remote access platforms

Approved MFA Methods

- Microsoft Authenticator
- Security Tokens
- Push Notifications
- Biometric Authentication

Target MFA Compliance:

100%

7. Account Lockout Controls

To protect against brute-force attacks and credential guessing, the following controls shall apply:

Control	Requirement
Failed Login Attempts	5
Lockout Duration	15 Minutes
Administrator Review	Required for repeated lockouts

Repeated lockouts may trigger a security investigation.

8. Password Change Requirements

Passwords must be changed according to the following schedule:

Account Type	Change Frequency
Standard User Accounts	Every 90 Days
Privileged Accounts	Every 60 Days
Service Accounts	Annual Review

Passwords must also be changed immediately following:

- A suspected security incident.
- Evidence of account compromise.
- Changes in privileged access.
- Organizational security directives.

9. Administrative Accounts

Administrative accounts require enhanced security controls because they provide elevated access to critical systems and information.

Administrative account requirements include:

- Separate administrative accounts.
- MFA is always enabled.
- Quarterly access reviews.
- Logging and monitoring activities.
- Approval before provisioning.

Privileged Access Principles

- Least Privilege
- Need-to-Know
- Role-Based Access Control (RBAC)

10. User Responsibilities

Employees

Employees are responsible for:

- Creating strong passwords.
- Protecting authentication credentials.
- Following policy requirements.
- Reporting suspicious activity.

Managers

Managers are responsible for:

- Supporting compliance.
- Reviewing access requirements.
- Escalating policy violations.

Information Security Team

The Information Security Team is responsible for:

- Policy maintenance.
- Monitoring compliance.
- Investigating violations.
- Managing authentication requirements.

11. Security Awareness Requirements

All personnel must complete annual security awareness training that includes:

- Password security
- Social engineering awareness
- Phishing prevention
- Credential protection
- Multifactor authentication

Training Completion Target:

100%

12. Compliance Monitoring

Key Performance Indicators (KPIs)

Metric	Target
MFA Adoption	100%
Password Compliance	95%
Security Training Completion	100%
Privileged Account Reviews	100%
Quarterly Access Reviews	100%
Password Reset Compliance	100%

Sample Compliance Dashboard

Control	Result
MFA Adoption	100%
Password Compliance	97%
Security Training	98%
Access Reviews	100%
Privileged Account Reviews	100%

13. Policy Violations

Failure to comply with this policy may result in:

- Verbal warning
- Written warning
- Suspension of access privileges
- Disciplinary action
- Employment termination
- Legal action where applicable

All violations shall be investigated by the Information Security Team.

14. Policy Exceptions

Requests for policy exceptions must include:

- Business justification
- Risk assessment
- Management approval
- Information Security approval
- Compensating controls
- Defined expiration date

All approved exceptions shall be documented and reviewed annually.

15. Conclusion

ABC Healthcare Services recognizes that strong password management and secure authentication practices are critical to protecting organizational information assets. Compliance with this policy helps reduce cybersecurity risks, strengthen access control measures, and support the organization's governance, risk management, and compliance objectives.

16. References

- ISO/IEC 27001:2022
- NIST Cybersecurity Framework
- CIS Critical Security Controls
- Access Control Policy
- Information Security Governance Framework

17. Document Control

Field	Value
Document Owner	Information Security Manager
Document ID	PWD-001
Version	1.0
Classification	Internal
Review Frequency	Annual
Next Review Date	June 1, 2027